PROJECT REVIEW PACK

Smart HMS
Implementation report draft

M.M. Rajaab Ahmed · E2340248 · Bachelor of Information Technology External · University of Moratuwa

13 October 2026. Review draft accompanying the submitted interim report. The implementation now supports the complete demonstrated outpatient visit workflow and the gaps identified in the later review. Live external messaging, a hosted production deployment, remote backup verification, human acceptance and clinical/language approval remain open. This document records implemented behaviour and available evidence; it is not a signed final submission or an approval to use real patient data.

Relationship to the interim report

The original interim report records analysis and design at its submission date. It should remain unchanged as a historical submission. Its appended SRS defines 85 functional requirements across authentication, patient management, appointments, department guidance, medical records, billing, notifications, feedback, doctor dashboard, reports and auditing, plus 15 numbered performance/security requirements. The companion requirements traceability CSV maps all 100 IDs to current components, test files and any remaining verification boundary.

The user subsequently requested a public hospital website, Socket.IO, charts, an Apple-inspired glass interface, email/SMS adapters and Sri Lankan settings. English-only delivery in SRS section 6.2 was explicitly expanded on 13 October to include Sinhala and Tamil interface translations. Stored free-text clinical data is preserved in its original language. The symptom keyword engine remains English-only and this limitation is displayed.

Project purpose and scope

Smart HMS coordinates registration, doctor availability, appointment reservation, reception check-in, consultation, prescriptions, billing, notifications and feedback. Four authenticated roles have separate workspaces. Public visitors can read published hospital details and approved doctor/service information. The design avoids exposing medical notes through administrative reports or public directories.

The prototype records cash and bank-transfer payments received outside the application; it does not process online card transactions. Laboratory, insurance, national health-system integration, trained diagnostic AI and video consultation are outside the implemented scope. The department guide evaluates bounded rules and explains keyword matches, with human/urgent fallback. No diagnostic accuracy or clinical validation is claimed.

Architecture

The client uses React and Vite with shared accessible form controls, route protection, charts and local language/display preferences. The server uses Node.js, Express and Mongoose against a MongoDB replica set. Authentication uses an HttpOnly session cookie carrying a JWT whose database session can be revoked. Business modules separate scheduling, clinical, billing, notifications, reporting, hospital settings and security recovery.

Critical state changes use MongoDB transactions and explicit doctor/patient/department write locks. A reservation is authoritative only after its transaction commits. Socket.IO authenticates the same session and signals authorised clients to refetch saved data; it does not create bookings or disclose clinical payloads. Periodic REST refresh remains a fallback. Notification and recovery workers process bounded batches and keep provider I/O outside clinical transactions.

Data and integrity

Principal entities include User, Patient, Doctor, Department, DoctorSchedule, AppointmentSlot, Appointment, Consultation, Bill, Payment, Notification, Delivery, Feedback, AuditLog, Session, PasswordReset and HospitalSettings. References connect the visit workflow; snapshots preserve booked doctor/department names and the consultation fee. LKR amounts are stored in integer minor units. Timestamps use UTC; date boundaries and displayed appointment times use Asia/Colombo.

Booking locks serialise conflicting changes, unique constraints prevent duplicate reservations, and cancellation/rescheduling release or replace slots transactionally. Completion creates the bill and in-app update in the same transaction. Prescription revisions preserve prior versions and require a reason. Payment retry keys avoid duplicate receipts, concurrent payments cannot overpay, and reversals preserve the original record. Deactivation preserves historical links.

Implemented workflows

Patients self-register, maintain permitted contact details, browse doctors and slots, book/reschedule/cancel, and view their own records, bills and notifications. Reception staff search or register walk-ins, review intake, confirm arrival and record payments. Doctors access assigned patients, review history/allergies, save consultation drafts, complete visits and revise prescriptions with a reason. Administrators manage staff, patient access, departments, publication, reports, feedback and audit review.

The latest changes add password recovery, audited patient activation/deactivation, department editing/deactivation, explicit public-profile publication, paginated doctor queues and a daily timeline. Password reset links expire in 15 minutes, are single-use and invalidate existing sessions on redemption. Successful login is serialised against password changes. Public directory queries expose only approved active profiles and omit private account contact details.

Interface and localisation

The responsive interface uses colourful indigo, mint, coral and violet surfaces, translucent navigation, readable clinical panels and an opaque-surface preference. Native select controls expose English, Sinhala and Tamil with a remembered browser preference. Language-specific fonts are self-hosted and licensed. Date/money rendering respects the selected locale while preserving LKR and the hospital timezone. Translated option labels retain stable server values, which is tested in the browser.

Translations cover interface controls and report descriptions. Names, medical notes, prescriptions, stored notifications and hospital-authored descriptions are not automatically translated. Uncatalogued server validation details may appear in English. Native-language review remains necessary; the supplied dictionaries are editable. Automated checks confirm matching keys, nonempty values and interpolation placeholders, not linguistic or clinical correctness.

Communication and public information

In-app notifications, reminders and role-scoped chart aggregates are implemented. The delivery outbox supports local preview, SMTP and Twilio adapters with opt-in, explicit approved recipients, bounded retry behaviour and provider-status handling. The running local installation uses simulated email and SMS. A public reception email address is contact information and does not configure SMTP.

Approved public hospital details are Smart HMS, Colombo 09, +94 115 279 429, smarthms@gmail.com and 24-hour opening every day. Administrators maintain private drafts and publish approved snapshots with version checks. Doctor/service publication is separately explicit: development accounts do not automatically become public clinicians. Public feedback testimonials are not generated from private patient feedback.

Security and operational controls

The API enforces role and ownership rules, strict schema validation, origin checks for cookie-authenticated writes, rate limits, secure production cookies and limited response projections. Login attempt IPs are visible only to administrators and retained for 30 days, while event metadata remains. Recovery tokens are hashed for redemption and encrypted in the private delivery queue. The local backup tool excludes sessions and reset links and authenticates encrypted archives before restoring to a new isolated database.

The local development app is managed by a user service. A daily 03:00 Asia/Colombo backup timer and one-minute readiness checks are enabled. A successful local backup was executed and the application resumed. Off-site encrypted copying has a prepared SSH/rsync helper, but no approved storage host has been supplied. HTTPS Docker/Caddy deployment is prepared and tested locally; no public domain or production host has been deployed in this phase.

Verification and limitations

The completed server suite contains 117 passing tests covering permissions, validation, conflict handling, transactions, billing, notifications, publication, recovery and auditing. All 31 Chrome scenarios passed across the completed regression and targeted reruns. Additional browser scenarios cover language persistence, translated form values, password recovery, public directory publication and full-period report export. The new scenarios and public pages passed on Chrome, Firefox and Linux WebKit. Automated WCAG A/AA scans passed on the public home, login, recovery, directory and doctor queue after correcting pagination contrast. This is not a complete accessibility certification or a test of actual Safari/Edge hardware.

A disposable synthetic-database benchmark used 100 pre-established sessions. Fifty concurrent dashboard API users completed 100 requests with p95 440 ms; 100 concurrent appointment-list reads completed with p95 263 ms; 50 concurrent transactional profile writers completed 100 writes with p95 178 ms. All 300 responses were successful. The shared-loopback IP rate limiter was disabled for this benchmark and is tested separately. These figures exclude login setup, broadband latency and browser rendering, so the SRS three-second dashboard target at 50 real users remains a hosted acceptance task.

Eleven encrypted backup/recovery checks and eight local production-mode smoke checks passed. These verify local mechanisms, not a remote restore, real provider delivery or sustained uptime. Browser regression details and exact log references are recorded separately in verification.md. No participant study, clinician evaluation, diagnosis accuracy, live SMS receipt or production uptime result has been fabricated.

Evaluation and remaining acceptance work

The core software workflow is demonstrable, and previously missing lifecycle/recovery/publication features now have explicit API and interface paths. The strongest evidence concerns transactional integrity and access controls under automated synthetic tests. The greatest remaining uncertainty concerns real operational conditions: provider credentials and sender approval, hosting/network performance, storage ownership, native language review and representative human users.

Complete the supplied acceptance checklist with patient, reception, doctor and administrator representatives. Record observed outcomes and actual devices. Verify one approved SMTP recipient and one approved SMS recipient against provider receipts; run the full workflow through the real HTTPS domain; measure page rendering under the intended hosted load; and restore an off-site backup into an isolated target. Resolve findings before changing the report status to deployment-ready.

Conclusion

Smart HMS now provides a coherent outpatient visit system with public information, four role workspaces, live updates, reporting, multilingual interface controls and recoverable local operation. Its implementation can support a final-year demonstration and evidence-based report review. Final operational acceptance depends on the remaining external services and human reviews listed above.

Evidence and supporting material

The original interim report remains the source for requirements and earlier analysis. Current supporting files are requirements-traceability.csv, use-cases.md, the rendered diagrams under docs/diagrams, user-manual.md, acceptance-plan.md, security-recovery.md, operations.md and verification.md. Read these alongside the source and automated tests rather than treating screenshots alone as proof of correctness.

Evidence inventory and reproduction

- Requirements: requirements-traceability.csv contains the 100 original SRS identifiers, descriptions, relevant components/tests and limits of the evidence. A mapped component is not a signed acceptance result.
- Test record: verification.md records completed commands, scenario counts, failed checks subsequently corrected, and local log references. Structured benchmark, production and recovery outputs are retained under docs/evidence.
- Behaviour: user-manual.md describes each role; use-cases.md and the DOT/SVG figures retain editable use-case sources. The supplied diagrams PDF has one readable view per page.
- Operations: operations.md documents the local service/timers, encrypted backup location, separate key custody, isolated restoration and off-site configuration still required.
- Human review: acceptance-plan.md provides scenarios and blank results for patient, reception, doctor and administrator representatives, plus Sinhala/Tamil and clinical reviewers.

Use Node.js 24 and the dependency lockfile. Start the test MongoDB replica set, then run npm test, npm run test:e2e and npm run test:translations. Disposable test databases isolate verification from development records. The load and recovery scripts create and remove their own synthetic databases. Reproduce hosted measurements separately; local figures must not be copied into production acceptance results.

Technical references

1. M.M. Rajaab Ahmed. Smart HMS interim report, including the Software Requirements Specification appendix. Supplied project document, July 2026; student identifier E2340248. The current review preserves that historical source.
2. OWASP Foundation. Forgot Password Cheat Sheet. Accessed 13 October 2026. https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html
3. OWASP Foundation. CSV Injection. Accessed 13 October 2026. https://owasp.org/www-community/attacks/CSV_Injection
4. Microsoft. Playwright: Accessibility testing. Accessed 13 October 2026. https://playwright.dev/docs/accessibility-testing
5. Microsoft. Playwright: Projects. Accessed 13 October 2026. https://playwright.dev/docs/test-projects

These sources inform individual implementation and testing decisions. They do not certify the application or establish clinical, linguistic or operational acceptance.